

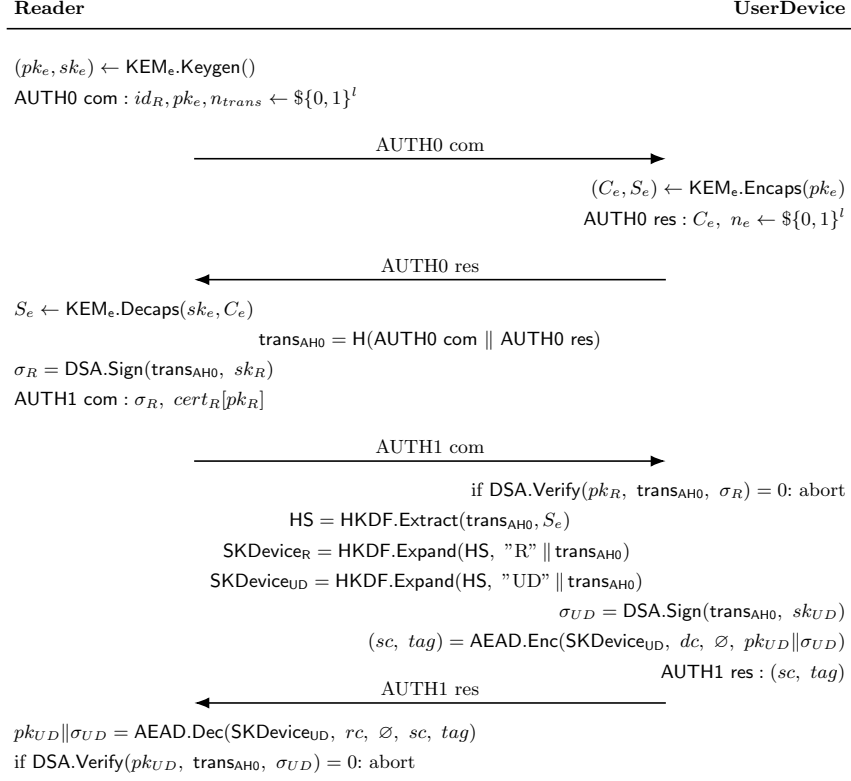


Figure 1: PQ-Aliro Standard-Expedited phase protocol overview.

1 THE PQ-ALIRO STANDARD-EXPEDITED PAHSE

We assume the existence of one or more trusted Certification Issuer (CI) for all Readers and User Devices. The CI possesses a long-term signing key pair (sk_{CI}, pk_{CI}) , where the cert of pk_{CI} is authentically distributed and pre-installed on all Readers and User Devices.

Each Reader R is provisioned with a CI-issued certificate that binds its long-term public key to its identity. Formally, the CI issues certificates

$$cert_R[pk_R] := \text{Sign}_{sk_{CI}}(id_R \parallel pk_R),$$

where pk_R denote the long-term public keys of R, respectively.

In addition, each User Device holds one or more data structures called a *Access Credential AC* which contains all the information necessary to perform the access transaction. An *Access Credential* may be associated with an *Access Document AD*. An *Access Document* is a CI-signed data structure that binds a User Device public key pk_{UD} to a set of access rights with respect to a specific

Reader or class of Readers. During protocol execution, the Reader enforces access control by authenticating the claimed pk_{UD} via a proof of possession of the corresponding secret key sk_{UD} (namely, a valid signature on the session transcript verifiable under pk_{UD}), and then authorizing pk_{UD} according to the rights encoded in the associated AD. For the protocol execution considered in this work, we assume that the corresponding AD has been distributed to the Reader and verified under the CI public key *prior* to the execution, through an external mechanism or a previous protocol run. Once a secure channel has been successfully established, other AD may additionally be transmitted or updated within the secure channel; however, such transmissions are not required for the security of the current protocol execution.

To maintain compatibility with Aliro's *Standard-Expedited* transaction profile, PQ-Aliro adopts the same two-round-trip (2-RTT) structure. In particular, a PQ-Aliro Standard-Expedited execution consists of an AUTH0 phase followed by an AUTH1 phase, where AUTH0 establishes session key material (via a PQ-KEM exchange) and AUTH1 provides mutual authentication and key confirmation bound to the AUTH0 transcript.

AUTH0:Ephemeral key exchange using KEM. After establishing the physical and transport layer, the PQ-Aliro standard-expedited phase may begin with the Reader sending an ephemeral KEM public key pk_R in the AUTH0 command message, as well as the transaction identifier id_R , a fresh nonce n_{trans} , command parameters, supported authentication policy, protocol version and extensions. The length of nonce, l should be adapted to the security level. The User Device replies in the AUTH0 response message with an encapsulation C_e and a fresh nonce n_e . The Reader decapsulates C_e with the ephemeral KEM private key sk_R . At this point, the Reader and the User Device have an unauthenticated shared secret S_e .

AUTH1: Establish the secure channel using DSA. After AUTH0 completion, a unique transcript $trans_{AH0}$ should be recorded by hashing the command and response messages. The Reader sends the AUTH1 command with the signature of $trans_{AH0}$ using its long term private key sk_R and the certificate of pk_R . If the User Device verifies the signature σ_R successfully, the key schedule will be performed, which applies HKDF operations to the share secret S_e and transcript $trans_{AH0}$ to derive the session keys SK_{Device_R} , $SK_{Device_{UD}}$ and other keys. Then, the AEAD ciphertext sc and tag tag are computed over the plaintext $(pk_{UD} \parallel \sigma_{UD})$ and the nonce(chosen as the device counter dc), under the session key $SK_{Device_{UD}}$ from UD. The AUTH1 command is send to Reader with sc and tag . The signature σ_{UD} is verified finally by the Reader to decide whether this session should be aborted. Besides, the nonce for the Reader is chosen as the reader counter rc . The device counter dc and the reader counter rc are initialized to the same value at the beginning of the session. The counter dc is incremented after each successful AEAD encryption performed by the User Device, while the reader counter rc is incremented after each successful AEAD decryption performed by the Reader.